

AST Smart Asset

Security Vulnerability & Findings Audit Report

Important Classification Note: During the security assessment, **6 test cases** were classified as **FAIL/FINDING**. However, these represent **3 unique security vulnerabilities**, as multiple test cases identified different entry points for the same underlying issue.

6

FAILED TEST CASES

3

UNIQUE VULNERABILITIES

100%

ASSESSMENT COVERAGE

TEST CASE TO VULNERABILITY MAPPING

FAILED TEST CASE DESCRIPTION	MAPPED FINDING ID
Asset Admin accessing an Engineering asset directly	AST-SEC-001
Asset Admin accessing an Engineering asset through the asset list	AST-SEC-001
Asset Admin accessing Engineering custody history	AST-SEC-001
Asset Admin accessing <code>/org-units</code> seeing out-of-scope units	AST-SEC-002
Asset Admin accessing <code>/locations</code> seeing out-of-scope locations	AST-SEC-002
Malformed JSON causing HTTP 500 Internal Server Error	AST-SEC-003

AST-SEC-001: Broken Organizational Authorization / BOLA

HIGH SEVERITY

CONFIRMED

Affected Role: `asset_admin`

Assigned Scope: Faculty of AI & Data Management

Out-of-Scope Tested: Engineering Department

DESCRIPTION

The application verifies that the user possesses the required role, but fails to check whether requested resources belong to the user's authorized organizational scope. This results in Broken Object Level Authorization (BOLA) combined with broken organizational controls across multiple endpoints:

- `GET /api/v1/assets/:assetId`
- `GET /api/v1/assets`
- `GET /api/v1/custody/:assetId/history`

AST-SEC-001 (Continued): Failed Tests & Technical Root Cause

FAILED TEST CASES BREAKDOWN

- **Test 1 – Direct Asset Access:** Requested Engineering asset via ID.
Observed: HTTP 200 OK with asset body. *Expected:* HTTP 403 Forbidden .
- **Test 2 – Asset List Scope Filtering:** Sent GET /api/v1/assets .
Observed: Out-of-scope assets included in response list. *Expected:* Scoped list returned.
- **Test 3 – Custody History:** Requested custody logs for Engineering asset.
Observed: HTTP 200 OK with full history. *Expected:* HTTP 403 Forbidden .

ROOT CAUSE ANALYSIS

The RBAC middleware validates role permissions but does not enforce organizational scope boundary rules. Although helper function `isOrgUnitInUserScope()` exists, controllers fail to invoke it.

Current: User Request → Role Check → Access Granted (Flawed)

Required: User Request → Role Check → Org Scope Check → Access Granted

REMEDIATION & VERIFICATION

Implement mandatory checks inside controllers before returning resource payloads. Ensure database queries filter records server-side for collection endpoints.

Expected Verification Result: Direct access and history requests return 403 Forbidden ; collection endpoints exclude unauthorized organizational units.

AST-SEC-002: Organizational Scope Disclosure / Broken Filtering

MEDIUM SEVERITY

CONFIRMED

Affected Role: asset_admin

Affected Endpoints: /org-units , /locations

DESCRIPTION & DISCOVERED BEHAVIOR

Organizational hierarchy and location metadata endpoints expose data outside the authenticated user's assigned scope. An admin assigned strictly to *Faculty of AI & Data Management* retrieved structural info for *Engineering* and *Allied Health*.

- **Test 4 – Organizational Units:** GET /api/v1/org-units returned full structural hierarchy.
- **Test 5 – Locations:** GET /api/v1/locations exposed locations tied to out-of-scope units.

SECURITY IMPACT & REMEDIATION

Exposes internal structural metadata, department relationships, and valid identifiers that assist attackers in crafting targeted secondary attacks.

Remediation: Enforce server-side filtering on /org-units and /locations matching the user's active organizational scope boundaries.

AST-SEC-003: Improper Error Handling for Malformed JSON

LOW SEVERITY

CONFIRMED

Affected Endpoint: POST /api/v1/assets

Observed Response: HTTP 500 Internal Server Error

DESCRIPTION & DISCOVERY

Submitting malformed JSON payloads to asset creation endpoints causes the application to raise an unhandled exception resulting in an HTTP 500 status rather than client-side validation errors (HTTP 400).

SECURITY IMPACT & REMEDIATION

No stack traces or sensitive credentials were disclosed in the response body. However, treating client payload errors as internal server failures pollutes error logs and complicates operational monitoring.

Remediation: Introduce centralized JSON parsing error handlers returning 400 Bad Request with error code INVALID_JSON .

OVERALL SECURITY RISK SUMMARY

FINDING ID	VULNERABILITY TITLE	SEVERITY	FAILED TESTS
AST-SEC-001	Broken Organizational Authorization / BOLA	HIGH	3
AST-SEC-002	Organizational Scope Disclosure / Broken Scope Filtering	MEDIUM	2
AST-SEC-003	Improper Error Handling for Malformed JSON	LOW	1
Total Failed Test Cases:			6

FINAL ASSESSMENT CONCLUSION

The assessment concluded with 6 failed test cases mapped cleanly into 3 distinct vulnerability categories.

The primary risk stems from AST-SEC-001 , where role-based checks (RBAC) operate independently without enforcing mandatory organizational scope filters. The multiple failed tests under this ID demonstrate different operational manifestations of the same core control gap rather than isolated bugs.

Addressing the authorization helpers and database scope queries will resolve 5 out of the 6 failed test cases simultaneously, significantly hardening the AST Smart Asset application.